SIMATS ENGINEERING
CSA6303- Threat Intelligence and Network Security
A2-Threat Intelligence Report

Assessment Questions

Subject	Threat Intelligence	**Total Marks**	50
Questions	6 (all compulsory)	**Marks per Question**	5
REg.No	192465051	**Name**	P Lakshmi Srinivasulu Reddy
Faculty	Dr.V.Parthipan	**Slot**	A

Instructions: Answer all questions. Each question carries 5 marks. Support answers with examples and diagrams where appropriate.

Code of Conduct:

*I **P Lakshmi Srinivasulu Reddy/192465051** (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

Signature of Student P Lakshmi Srinivasulu Reddy

A2-Vulnerability Assessment Report

Q1. Explain the common types of network attacks: malware, phishing, DoS and DDoS. Give one example and one preventive measure for each. (10 marks)

Key points: malware types (virus, worm, trojan, ransomware, spyware); phishing via deceptive emails, links or sites to steal credentials; DoS from a single source versus DDoS from a botnet; preventive measures such as antivirus, user awareness training, rate limiting, firewalls and CDN or traffic scrubbing.

Q2. What is a Man-in-the-Middle (MitM) attack? Describe how it works and the techniques used to carry it out, and list the countermeasures. (8 marks)

Key points: the attacker intercepts and may alter communication between two parties; techniques include ARP poisoning, rogue Wi-Fi access points, DNS spoofing and session hijacking; countermeasures include HTTPS/TLS, VPN, certificate validation, HSTS and dynamic ARP inspection.

Q3. Differentiate between spoofing and sniffing. Describe the types of spoofing and explain how sniffing can be detected or prevented. (8 marks)

Key points: spoofing is forging identity (IP, MAC, email or DNS spoofing); sniffing is passively capturing packets (Wireshark, tcpdump) and mainly exposes unencrypted data; prevention includes encryption, switched networks, port security and anti-spoofing filters.

Q4. Define vulnerability assessment. Explain its steps and describe the contents of a good vulnerability assessment report. (8 marks)

Key points: the process is asset identification, scanning (Nessus, OpenVAS), analysis, risk rating and reporting; the report contains an executive summary, scope and methodology, findings with CVE IDs, CVSS severity scores, evidence, risk impact and prioritized remediation recommendations; also mention how it differs from penetration testing.

Q5. What is Open-Source Intelligence (OSINT)? Discuss the common threat data sources and the techniques used to collect threat data. (8 marks)

Key points: OSINT draws on public sources such as WHOIS, Shodan, social media, news, forums, code repositories and the CVE/NVD databases; also cover commercial and internal sources (logs, honeypots) and collection techniques such as passive collection, web scraping and DNS or domain lookups; mention legal and ethical considerations.

Q6. What are Indicators of Compromise (IoCs)? Explain the types of IoCs and describe how threat feeds help organizations improve their defense. (8 marks)

Key points: IoCs are artifacts such as file hashes, malicious IPs, domains, URLs, registry keys and unusual network traffic; threat feeds (open-source or commercial, in formats like STIX/TAXII) deliver them for SIEM or firewall blocking and faster detection; limitations include false positives, stale data and the need for context.

A2 – Vulnerability Assessment Report: Answers

CSA6303 – Threat Intelligence and Network Security | SIMATS Engineering | CO2: Identify common network attacks and analyze threat intelligence sources and data collection techniques

Q1. Common Types of Network Attacks: Malware, Phishing, DoS and DDoS (10 marks)

A network attack is any deliberate attempt to gain unauthorized access to, disrupt, steal from or damage a network, its devices or its data. Four of the most common types are described below.

1. Malware

Malware (malicious software) is code designed to harm, exploit or take control of a system without the owner's consent. Common types are:

- **Virus:** attaches itself to a legitimate file or program and spreads when the host file is executed.
- **Worm:** a self-replicating program that spreads across networks on its own, without user action, by exploiting vulnerabilities.
- **Trojan:** malware disguised as useful software; it opens a backdoor or steals data once the user installs it.
- **Ransomware:** encrypts the victim's files and demands payment for the decryption key.
- **Spyware:** secretly monitors the user and steals information such as passwords, keystrokes and browsing activity.

Example: The WannaCry ransomware (2017) spread as a worm through the SMB vulnerability in Windows and encrypted files on hundreds of thousands of computers.

Preventive measures: Install and update antivirus/EDR software, patch operating systems and applications promptly, restrict administrator privileges, keep offline backups and avoid running untrusted attachments or downloads.

2. Phishing

Phishing is a social-engineering attack in which the attacker sends deceptive emails, messages, links or fake websites that appear to come from a trusted source, in order to trick the victim into revealing credentials, financial details or installing malware. Variants include spear phishing (targeted at a specific person), whaling (aimed at senior executives), smishing (via SMS) and vishing (via voice calls).

Example: An email that appears to be from a bank says "Your account is locked – click here to verify" and leads to a look-alike login page that captures the user's username and password.

Preventive measures: User awareness training, email filtering and anti-spoofing controls (SPF, DKIM, DMARC), multi-factor authentication (so stolen passwords alone are not enough), checking URLs before clicking and reporting suspicious mail.

3. Denial of Service (DoS)

A DoS attack makes a server, service or network unavailable to legitimate users by overwhelming it with traffic or malformed requests, or by exhausting its resources such as bandwidth, CPU or memory. The

flood originates from a **single source**. Common forms include SYN flood, ICMP (ping) flood and the Ping of Death.

Example: A SYN flood sends a large number of TCP SYN packets without completing the handshake, filling the server's connection table so real users cannot connect.

Preventive measures: Rate limiting, firewall and IPS rules that block abusive sources, SYN cookies, proper server configuration and timeouts.

4. Distributed Denial of Service (DDoS)

A DDoS attack has the same goal as DoS but the traffic comes from **many compromised devices (a botnet)** controlled by the attacker through a command-and-control server. Because the traffic comes from thousands of different IP addresses, it is much harder to block and much larger in volume.

Example: The Mirai botnet (2016) used hacked IoT devices such as cameras and routers to attack the DNS provider Dyn, taking down sites such as Twitter, Netflix and Reddit.

Preventive measures: CDN and traffic scrubbing services, load balancing and over-provisioned bandwidth, anycast routing, upstream filtering with the ISP, rate limiting and securing IoT devices so they cannot be recruited into botnets.

Summary Table

Attack	Main goal	Example	Key prevention
Malware	Damage, steal or control	WannaCry ransomware	Antivirus, patching, backups
Phishing	Steal credentials	Fake bank login email	Awareness training, MFA, email filters
DoS	Make a service unavailable (single source)	SYN flood	Rate limiting, firewall
DDoS	Make a service unavailable (botnet)	Mirai attack on Dyn	CDN, traffic scrubbing

Q2. Man-in-the-Middle (MitM) Attack (8 marks)

Definition

A Man-in-the-Middle attack occurs when an attacker secretly positions themselves between two communicating parties (for example a user and a web server), intercepting the traffic and possibly altering it. Both parties believe they are talking directly to each other. MitM threatens **confidentiality** (eavesdropping) and **integrity** (modification of data).

How It Works

1. **Interception:** The attacker inserts themselves into the communication path, either physically or logically.
2. **Decryption/Relay:** The attacker relays messages between the victim and the real server, reading or modifying them in transit.
3. **Exploitation:** The attacker harvests credentials, session cookies, financial data or injects malicious content, while the victim notices nothing.

Techniques Used

- **ARP poisoning (spoofing):** The attacker sends forged ARP replies so that the victim's traffic is sent to the attacker's MAC address instead of the real gateway.
- **Rogue Wi-Fi access point / Evil twin:** A fake hotspot with a legitimate-looking name; everything users send through it can be captured.
- **DNS spoofing (cache poisoning):** False DNS records redirect users to a malicious site when they type a legitimate domain name.
- **Session hijacking:** The attacker steals a valid session ID or cookie and takes over the authenticated session.
- **SSL stripping:** Downgrades an HTTPS connection to HTTP so the traffic can be read.

Countermeasures

- Use **HTTPS/TLS** for all communication and enforce **HSTS** to prevent downgrade attacks.
- Use a **VPN** on untrusted networks such as public Wi-Fi.
- Perform proper **certificate validation** and never ignore browser certificate warnings.
- Enable **Dynamic ARP Inspection (DAI)** and DHCP snooping on switches.
- Use secure DNS (DNSSEC, DNS over HTTPS), strong mutual authentication and multi-factor authentication.
- Avoid unknown Wi-Fi networks and use WPA2/WPA3 with strong passwords.

Q3. Spoofing versus Sniffing (8 marks)

Difference Between Spoofing and Sniffing

Basis	Spoofing	Sniffing
Meaning	Forging or falsifying an identity to impersonate a trusted entity	Capturing and inspecting network packets as they pass
Nature	Active attack (sends forged data)	Mostly passive attack (listens without altering traffic)
Goal	Gain unauthorized access, bypass trust, redirect or deceive	Obtain information such as passwords and messages
Tools	Ettercap, Scapy, hping	Wireshark, tcpdump
Main target	Authentication and trust relationships	Confidentiality of unencrypted data

Types of Spoofing

- **IP spoofing:** The attacker forges the source IP address in packets to hide identity or impersonate another host; commonly used in DDoS attacks.
- **MAC spoofing:** Changing the MAC address of a network card to bypass MAC filtering or impersonate a device.
- **Email spoofing:** Forging the sender address of an email so it looks legitimate; widely used in phishing.
- **DNS spoofing:** Supplying false DNS responses so that a domain resolves to a malicious IP address.
- **ARP spoofing:** Sending fake ARP messages to link the attacker's MAC address with a legitimate IP address.

Sniffing

Sniffing is the process of capturing data packets travelling across a network using packet analyzers such as Wireshark or tcpdump, usually with the network card in promiscuous mode. It mainly exposes **unencrypted data** such as HTTP, FTP and Telnet traffic, including usernames, passwords and emails. Legitimate administrators also use sniffers for troubleshooting, which is why the tool itself is not illegal; misuse is.

Detecting Sniffing

- Check for network interfaces running in **promiscuous mode** (for example with `ifconfig` or `ip link`).
- Use anti-sniffer tools and intrusion detection systems to spot unusual ARP traffic or duplicate MAC addresses.
- Monitor for abnormal latency and unexpected devices on the network.
- Send bait packets or ping tests to see if a host responds to traffic not addressed to it.

Preventing Sniffing and Spoofing

- **Encrypt traffic** using HTTPS, SSH, SFTP, TLS and VPNs, so captured packets are unreadable.
- Use **switched networks** instead of hubs, so traffic is not broadcast to every port.
- Enable **port security**, dynamic ARP inspection and DHCP snooping on switches.
- Apply **anti-spoofing filters** such as ingress/egress filtering (BCP 38) and unicast reverse path forwarding.
- Use strong authentication, network segmentation and regular monitoring.

Q4. Vulnerability Assessment (8 marks)

Definition

A vulnerability assessment is a systematic process of identifying, classifying and prioritizing security weaknesses in systems, networks, applications and devices so they can be fixed before attackers exploit them.

Steps in a Vulnerability Assessment

1. **Asset identification and scoping:** Define what is to be assessed (servers, devices, applications, IP ranges) and rank assets by business importance.
2. **Vulnerability scanning:** Use automated tools such as **Nessus, OpenVAS, Qualys or Nmap** to detect missing patches, misconfigurations, weak passwords and open ports.
3. **Analysis:** Verify the results, remove false positives and understand how each weakness could be exploited.
4. **Risk rating and prioritization:** Score each finding using **CVSS** (Common Vulnerability Scoring System) and consider asset value and exploitability to decide what to fix first.
5. **Reporting:** Document findings and recommendations for technical and management audiences.
6. **Remediation and re-scan:** Apply patches or controls and re-scan to confirm the issues are fixed.

Contents of a Good Vulnerability Assessment Report

- **Executive summary:** A non-technical overview of overall risk, key findings and top recommendations for management.
- **Scope and methodology:** Systems assessed, dates, tools used and the approach followed.
- **Findings:** Each vulnerability with its name, affected asset and **CVE ID**.
- **Severity rating:** CVSS score and classification (Critical, High, Medium, Low).
- **Evidence:** Screenshots, scan output or proof that the vulnerability exists.
- **Risk and impact:** What could happen if the weakness is exploited (data loss, downtime, compliance issues).
- **Prioritized remediation recommendations:** Specific fixes such as patches, configuration changes or compensating controls, ordered by urgency.
- **Conclusion and appendices:** Overall summary, tool output and references.

Vulnerability Assessment versus Penetration Testing

Vulnerability Assessment	Penetration Testing
Identifies and lists weaknesses	Actively exploits weaknesses to prove impact
Mostly automated, broad coverage	Mostly manual, deep and targeted
Lower risk to systems	Higher risk, needs careful authorization
Done frequently (monthly/quarterly)	Done periodically (annually or after major changes)
Result: list of prioritized vulnerabilities	Result: demonstrated attack paths and real-world impact

Q5. Open-Source Intelligence (OSINT), Threat Data Sources and Collection Techniques (8 marks)

What is OSINT?

Open-Source Intelligence (OSINT) is intelligence gathered from **publicly available sources** that anyone can legally access. In cybersecurity it is used to understand attackers, discover an organization's exposed assets and identify emerging threats. Both defenders and attackers use OSINT.

Common Threat Data Sources

1. Open (public) sources

- **WHOIS and DNS records:** domain ownership, registration dates and name servers.
- **Shodan and Censys:** search engines for internet-connected devices, open ports and banners.
- **Social media and professional networks:** employee information, leaked details and attacker chatter.
- **News, blogs and security advisories:** reports on new attacks and vulnerabilities.
- **Forums and paste sites:** hacker forums and dark web discussions where tools and stolen data are traded.
- **Code repositories (GitHub):** accidentally exposed API keys, passwords and source code.
- **CVE and NVD databases:** official catalogues of known vulnerabilities and their severity scores.

2. Commercial sources: Paid threat intelligence providers (for example Recorded Future, CrowdStrike, Mandiant) that supply curated, analyzed feeds and reports.

3. Internal sources: The organization's own firewall, IDS/IPS, server and endpoint logs, SIEM data, email gateway records and **honeypots** (decoy systems that attract and record attacker behaviour).

Techniques Used to Collect Threat Data

- **Passive collection:** Gathering information without interacting with the target (reading public records, search engines, cached pages), which leaves no trace.
- **Active collection:** Interacting with targets, such as port scanning, which can be detected.
- **Web scraping and crawling:** Automated tools that collect data from websites, forums and social media at scale.
- **DNS and domain lookups:** WHOIS, reverse DNS, subdomain enumeration and certificate transparency logs to map infrastructure.
- **Search engine techniques:** Advanced operators ("Google dorking") to find exposed files and pages.
- **Honeypots and sensors:** Collect real attack data such as source IPs, malware samples and exploit attempts.
- **Feed ingestion:** Automatically importing threat feeds into a SIEM or threat intelligence platform.
- **Tools:** Maltego, theHarvester, Recon-ng, SpiderFoot, Shodan.

Legal and Ethical Considerations

- Use only **lawfully accessible** information; do not break into accounts, bypass authentication or use stolen credentials.
- Respect **privacy laws** (such as GDPR and India's data protection law) and website terms of service.
- Obtain **authorization** before any active scanning of systems you do not own.
- Verify the reliability of sources, protect collected personal data and use findings only for defensive or authorized purposes.

Q6. Indicators of Compromise (IoCs) and Threat Feeds (8 marks)

What are IoCs?

Indicators of Compromise are pieces of forensic evidence or artifacts that show a system or network has been breached or is under attack. They help security teams detect, investigate and respond to incidents.

Types of IoCs

- **File-based indicators:** File hashes (MD5, SHA-1, SHA-256) of known malware, suspicious file names and paths.
- **Network indicators:** Malicious IP addresses, domains, URLs, unusual outbound connections, traffic to command-and-control servers, abnormal data transfer volumes and unexpected ports or protocols.
- **Host-based indicators:** Unusual registry key changes, new or modified services, unexpected scheduled tasks, unknown processes and unauthorized user accounts.
- **Email indicators:** Malicious sender addresses, subject lines and attachment names used in phishing.
- **Behavioral indicators:** Logins at odd hours, privilege escalation, repeated failed logins and large data movements.

How Threat Feeds Help Organizations Improve Defense

Threat feeds are continuously updated streams of threat data, such as malicious IPs, domains, URLs and file hashes, provided by open-source communities (for example AlienVault OTX, abuse.ch, MISP) or commercial vendors. They are delivered in standard formats such as **STIX** (the language describing the data) and **TAXII** (the protocol for exchanging it).

They improve defense by:

- **Automated blocking:** IoCs can be pushed to firewalls, proxies, DNS filters and endpoint tools to block known bad IPs and domains.
- **Faster detection:** SIEM and IDS systems match logs against feed data to raise alerts quickly.
- **Proactive defense:** Organizations learn about attacks seen elsewhere before they are hit.
- **Incident response:** Analysts use IoCs to hunt for the same threat across the network and scope an incident.
- **Information sharing:** Communities and sectors share intelligence so everyone benefits.

Limitations

- **False positives:** Legitimate IPs or domains may be wrongly flagged, causing blocked services.
- **Stale data:** Attackers change IPs, domains and hashes quickly, so old indicators lose value.
- **Lack of context:** An IoC alone does not explain who, why or how severe; it must be enriched and prioritized.
- **Volume and quality:** Too many feeds create noise and overload analysts.
- **Easy evasion:** Simple indicators such as hashes can be bypassed by small changes to malware.

For these reasons, IoCs should be combined with context, behavioral detection and human analysis.